Segurança em Redes Corporativas: Análise, Implementação e Avaliação de Mecanismos de Proteção

Guilherme Miranda de Matos Carlos Eduardo de Sousa Arnaud Pedro Amorim de Gregori

Paulo Henrique Borges Martins

Introdução

A crescente dependência das organizações em relação às redes de computadores e à conectividade digital trouxe, junto com os ganhos de produtividade e comunicação, um aumento significativo da superfície de ataque a que essas infraestruturas estão expostas. Falhas na proteção de dados em trânsito, na gestão de identidades digitais e na configuração de serviços de rede podem comprometer os três pilares fundamentais da Segurança da Informação: confidencialidade, integridade e disponibilidade [1].

Neste projeto, o grupo atuou como uma equipe de consultoria em segurança contratada para avaliar a infraestrutura de uma empresa fictícia denominada SecureTech, seguindo uma abordagem prática e progressiva: inicia-se pela identificação de riscos associados a protocolos não criptografados, avança-se para o estudo dos mecanismos de criptografia em trânsito (TLS/HTTPS) e da infraestrutura de chaves públicas que sustenta a confiança na Internet, e conclui-se com a análise de vulnerabilidades de serviços de rede, a implementação de políticas de firewall e o estudo de um ataque real. Essa progressão reflete o ciclo de trabalho de um profissional de segurança: primeiro identificar e compreender os riscos, para em seguida propor e validar mecanismos de proteção [2].

Ao longo do relatório, cada parte é acompanhada de evidências práticas obtidas por meio de ferramentas amplamente utilizadas no mercado, como Wireshark, OpenSSL e Nmap, de modo a conectar os conceitos teóricos estudados com situações reais de análise e resposta a incidentes de segurança.

Fundamentação Teórica

Protocolos HTTP e HTTPS

O HTTP (*Hypertext Transfer Protocol*) é um protocolo de aplicação que opera sobre TCP e é responsável pela troca de mensagens entre clientes e servidores Web, definindo métodos como GET e POST, além de cabeçalhos que carregam metadados da requisição e da resposta [1]. Por padrão, o HTTP transmite seus dados em texto claro, o que expõe informações sensíveis a qualquer entidade capaz de interceptar o tráfego na rede.

O HTTPS surge como uma extensão do HTTP que adiciona uma camada de segurança por meio do TLS (*Transport Layer Security*), garantindo confidencialidade (através de cifração), integridade (através de códigos de autenticação de mensagem) e autenticidade (através de certificados digitais) à comunicação [2].

TLS e o Handshake Criptográfico

O TLS é um protocolo de camada de transporte responsável por estabelecer um canal seguro entre cliente e servidor antes da troca de dados da aplicação. Esse processo, conhecido como *handshake*, envolve a negociação de parâmetros criptográficos (mensagens *Client Hello* e *Server Hello*), a apresentação do certificado digital do servidor (*Certificate*), o estabelecimento de uma chave de sessão compartilhada (*Key Exchange*) e a confirmação de que ambas as partes concluíram a negociação com sucesso (*Finished*) [1]. Após esse processo, toda a comunicação subsequente é cifrada utilizando a chave de sessão negociada, impedindo que terceiros na rede leiam o conteúdo transmitido, ainda que metadados como o endereço IP de destino e o SNI (*Server Name Indication*) possam permanecer visíveis.

Certificados Digitais e Infraestrutura de Chaves Públicas (PKI)

Um certificado digital associa uma chave pública a uma identidade (domínio ou organização), sendo assinado digitalmente por uma Autoridade Certificadora (CA) que atesta essa associação. A confiança em um certificado não é absoluta, mas construída por meio de uma cadeia hierárquica: uma Root CA, cuja chave é previamente distribuída e confiada pelos sistemas operacionais e navegadores, assina certificados de Autoridades Certificadoras Intermediárias, que por sua vez assinam os certificados dos servidores finais [2]. Esse modelo, conhecido como Infraestrutura de Chaves Públicas (PKI), permite que um navegador valide

a autenticidade de um servidor sem precisar conhecer previamente sua chave, bastando confiar na Root CA no topo da cadeia. A quebra de qualquer elo dessa cadeia — por certificado expirado, revogado ou emissor não confiável — invalida a confiança em toda a comunicação.

Varredura de Rede e Análise de Vulnerabilidades

A varredura de portas (*port scanning*) é uma técnica utilizada tanto por administradores de segurança quanto por atacantes para identificar quais serviços estão ativos em um host e escutando conexões de rede. Ferramentas como o Nmap permitem não apenas identificar portas abertas, mas também inferir a versão exata do serviço em execução, informação essencial para avaliar se aquele serviço possui vulnerabilidades conhecidas associadas à sua versão [1]. Do ponto de vista defensivo, esse tipo de varredura é utilizado para mapear a superfície de ataque de uma organização; do ponto de vista ofensivo, é tipicamente a primeira etapa de um ataque, permitindo o reconhecimento do alvo antes da exploração de falhas específicas.

Firewalls e Controle de Acesso

Um firewall é um mecanismo de segurança, implementado em software ou hardware, que controla o tráfego de rede com base em um conjunto de regras pré-definidas, permitindo ou bloqueando pacotes de acordo com critérios como endereço IP de origem/destino, porta e protocolo [2]. Firewalls atuam como uma primeira linha de defesa perimetral, restringindo a exposição de serviços internos à rede externa, mas não substituem outras camadas de segurança, como a validação de entradas em aplicações Web ou a autenticação forte de usuários, uma vez que não analisam o conteúdo da aplicação nem impedem ataques originados de dentro da própria rede protegida.

Ataques Comuns em Redes Corporativas

Entre as ameaças mais recorrentes em ambientes corporativos estão o *Man-in-the-Middle* (interceptação e possível alteração de dados em trânsito), o *phishing* (engenharia social para obtenção de credenciais), o *spoofing* (falsificação de identidade de origem) e ataques de negação de serviço (DDoS) [1]. A compreensão desses vetores de ataque é essencial para justificar tecnicamente a adoção de mecanismos de proteção como criptografia em trânsito, autenticação multifator e segmentação de rede, temas explorados ao longo das demais seções deste relatório.

PARTE I – INVESTIGAÇÃO DE TRÁFEGO NÃO SEGURO

O objetivo desta parte da análise é acessar uma página utilizando o protocolo HTTP e capturar pacotes de rede para analisar os riscos de uma comunicação não criptografada. O site escolhido foi o "example.com". É um site extremamente simples mantido pela IANA para documentação e exemplos. Para acessá-lo foi usado o comando de terminal "curl http://example.com"; pois, caso o acesso fosse feito por um navegador, seriam abertas duas frentes de comunicação: uma HTTP e outra HTTPS, o que poluiria a comunicação e dificultaria a análise.

Captura de Tráfego HTTP

Os pacotes de rede capturados são mostrados na Figura 1. A partir dela, é possível identificar O IP de origem e de destino de cada pacote, e visualizar que foi utilizado o método HTTP GET (mostrados em vermelho na Figura 1)

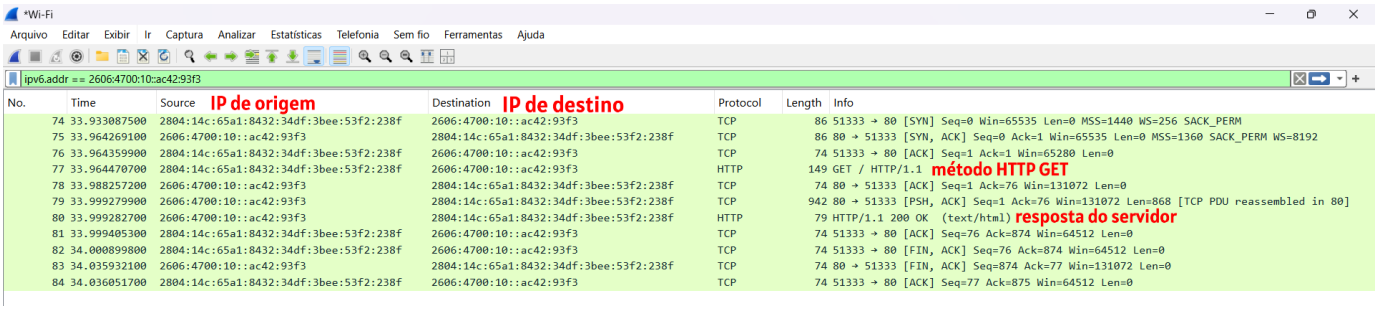


Figura 1. Captura de Tráfego HTTP

Além disso, ao analisar os detalhes dos pacotes, é possível verificar a URL requisitada (example.com) e os metadados que compõem os cabeçalhos HTTP (identificados por "\r\n"no final da linha). Os detalhes do cabeçalho HTTP dos pacotes 77 (requisição) e 80 (resposta) estão nas Figuras 2 e 3, respectivamente. Os cabeçalhos informam, por exemplo, o cliente que fez a solicitação(User Agent: curl), a data da comunicação, o tipo do conteúdo retornado(text/html), o servidor que respondeu a solicitação (cloudflare), entre outras informações.

Por fim, também é possível visualizar o conteúdo do HTML retornado em plain text, mostrado na figura 4.



Figura 2. Detalhes pacote 77 (Requisição HTTP)

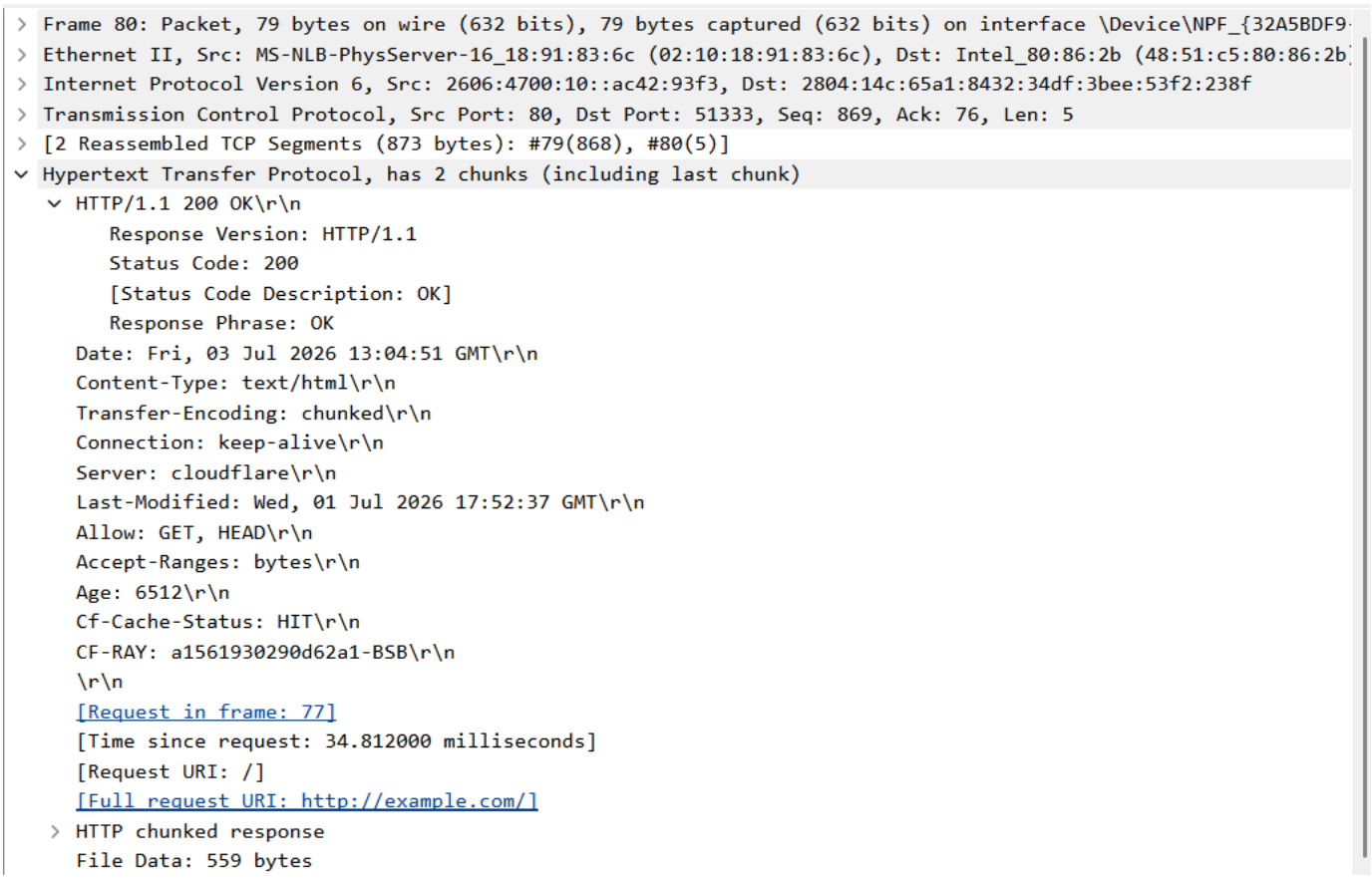


Figura 3. Detalhes pacote 80 (Resposta HTTP)

Portanto, fica claro que, como os dados não são criptografados, o HTTP falha nos três pilares da Segurança da Informação: Confidencialidade: Qualquer um na rede lê os dados, como cookies de sessão, metadados do navegador e dispositivo (User-Agent), arquivos baixados ou enviados; Integridade: Os dados podem ser alterados no caminho (MitM); Autenticidade: Você não tem garantia de que o servidor do outro lado é realmente quem diz ser (Spoofing).

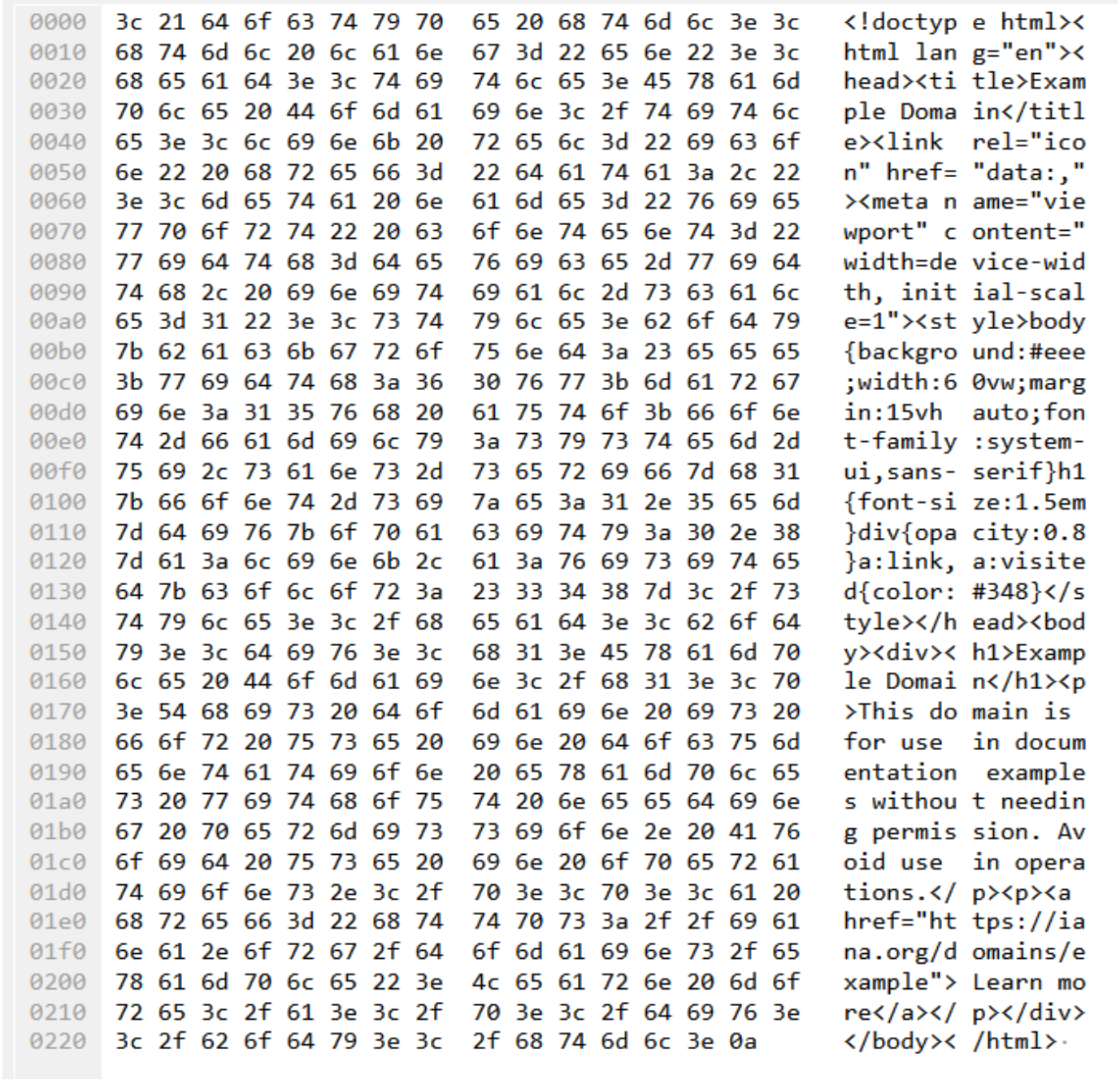


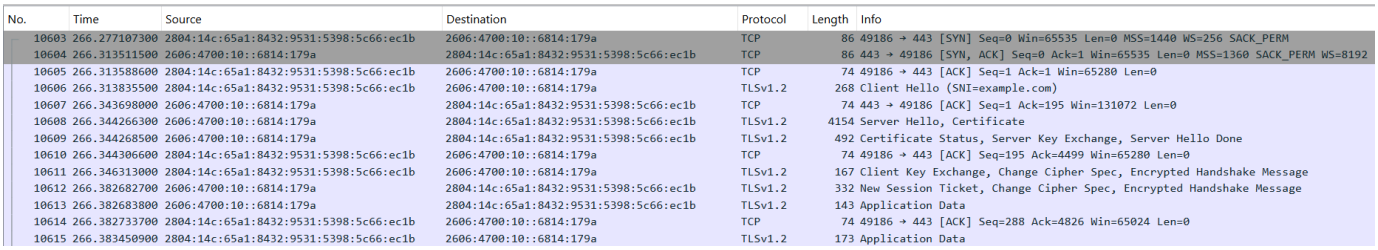
Figura 4. valor retornado no pacote 80 (Resposta HTTP)

PARTE II – ESTUDO DO TLS E HTTPS

Com o objetivo de analisar como a criptografia é usada para proteger as comunicações, foi feita uma captura de sessão HTTPS utilizando a ferramenta Wireshark. O site acessado foi o www.example.com (o mesmo acessado na PARTE 1) por meio do navegador Firefox e os resultados e análises são descritos a seguir:

A. Captura de Sessão HTTPS

A versão padrão do TLS utilizada pelo navegador é a 1.3, porém, nessa versão o certificado é enviado já em um pacote criptografado. Para que o envio do certificado pudesse ser visualizado, a configuração padrão do navegador foi alterada para que fosse utilizada a versão 1.2 do TLS.



No.	Time	Source	Destination	Protocol	Length	Info
10603	266.277107300	2804:14c:65a1:8432:9531:5398:5c66:ec1b	2606:4700:10::6814:179a	TCP	86	49186 → 443 [SYN] Seq=0 Win=65535 Len=0 MSS=1440 WS=256 SACK_PERM
10604	266.313511500	2606:4700:10::6814:179a	2804:14c:65a1:8432:9531:5398:5c66:ec1b	TCP	86	443 → 49186 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1360 SACK_PERM WS=8192
10605	266.313588600	2804:14c:65a1:8432:9531:5398:5c66:ec1b	2606:4700:10::6814:179a	TCP	74	49186 → 443 [ACK] Seq=1 Ack=1 Win=65280 Len=0
10606	266.313835500	2804:14c:65a1:8432:9531:5398:5c66:ec1b	2606:4700:10::6814:179a	TLSv1.2	268	Client Hello (SNI=example.com)
10607	266.343698000	2606:4700:10::6814:179a	2804:14c:65a1:8432:9531:5398:5c66:ec1b	TCP	74	443 → 49186 [ACK] Seq=1 Ack=195 Win=131072 Len=0
10608	266.344266300	2606:4700:10::6814:179a	2804:14c:65a1:8432:9531:5398:5c66:ec1b	TLSv1.2	4154	Server Hello, Certificate
10609	266.344268500	2606:4700:10::6814:179a	2804:14c:65a1:8432:9531:5398:5c66:ec1b	TLSv1.2	492	Certificate Status, Server Key Exchange, Server Hello Done
10610	266.344306600	2804:14c:65a1:8432:9531:5398:5c66:ec1b	2606:4700:10::6814:179a	TCP	74	49186 → 443 [ACK] Seq=195 Ack=4499 Win=65280 Len=0
10611	266.346313000	2804:14c:65a1:8432:9531:5398:5c66:ec1b	2606:4700:10::6814:179a	TLSv1.2	167	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
10612	266.382682700	2606:4700:10::6814:179a	2804:14c:65a1:8432:9531:5398:5c66:ec1b	TLSv1.2	332	New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
10613	266.382683800	2606:4700:10::6814:179a	2804:14c:65a1:8432:9531:5398:5c66:ec1b	TLSv1.2	143	Application Data
10614	266.382733700	2804:14c:65a1:8432:9531:5398:5c66:ec1b	2606:4700:10::6814:179a	TCP	74	49186 → 443 [ACK] Seq=288 Ack=4826 Win=65024 Len=0
10615	266.383450900	2804:14c:65a1:8432:9531:5398:5c66:ec1b	2606:4700:10::6814:179a	TLSv1.2	173	Application Data

Figura 5. Hand Shake TLS

Na figura 5, é possível visualizar o estabelecimento da conexão nos três primeiros pacotes (pacotes 10603, 10604 e 1065). Nesses pacotes, é feito o three-way handshake do TCP (10603 [SYN]: O cliente inicia o contato na porta 443 do servidor; 10604 [SYN, ACK]: O servidor responde concordando com a conexão; 10605 [ACK]: O cliente confirma o recebimento.)

Logo após, pode-se identificar o handshake TLS, do pacote 10606 ao pacote 10612.

B. Identificação das Mensagens TLS

A captura dos pacotes permite a identificação das etapas do handshake TLS. Para uma melhor visualização das mensagens do handshake Foi construído um diagrama de sequência, mostrado na figura 6 . Além disso, a figura (7) destaca a identificação de cada etapa na captura no wireshark (pacotes 6 ao 12). Os detalhes de cada etapa, bem como o número do pacote em que elas se encontram estão descritos a seguir.

- **Client Hello (Pacote 10606):** O cliente inicia o handshake TLS enviando o conjunto de algoritmos de criptografia disponíveis (*Cipher Suites*), a versão máxima do protocolo suportada e o seu valor aleatório (*Client Random*) para geração posterior de chaves.
- **Server Hello (Pacote 10608):** O servidor responde ao cliente selecionando a versão do protocolo, a criptografia que será utilizada na sessão e enviando o seu próprio valor aleatório (*Server Random*).
- **Certificate (Pacote 10608):** O servidor envia sua cadeia de certificados digitais contendo sua chave pública estática, permitindo que o cliente valide a autenticidade e a identidade do site.
- **Server Key Exchange (Pacote 10609):** Como a suíte de criptografia escolhida utiliza algoritmos efêmeros (como ECDHE), o servidor envia uma mensagem extra contendo os parâmetros matemáticos temporários necessários para o cálculo seguro da chave.
- **Server Hello Done (Pacote 10609):** O servidor emite esta mensagem para sinalizar ao cliente que encerrou sua fase inicial de envio de dados e que aguarda a resposta do lado cliente.
- **Client Key Exchange (Pacote 10611):** O cliente envia seus próprios parâmetros de chave pública temporária, permitindo que ambos os lados realizem o cálculo computacional da chave simétrica final (*Master Secret*).
- **Change Cipher Spec - Cliente (Pacote 10611):** Uma notificação de controle que avisa o servidor que todos os próximos pacotes enviados pelo cliente a partir daquele instante serão transmitidos de forma criptografada.
- **Finished - Cliente (Pacote 10611):** A primeira mensagem cifrada do cliente (exibida no Wireshark como *Encrypted Handshake Message*). Ela carrega um hash de todo o histórico do handshake para verificar se houve integridade e se as chaves funcionam.
- **Change Cipher Spec - Servidor (Pacote 10612):** O servidor envia sua própria sinalização de controle, indicando que também ativou o motor de criptografia para as suas transmissões de saída.
- **Finished - Servidor (Pacote 10612):** O servidor envia seu próprio hash de verificação criptografado. Uma vez decodificado e validado com sucesso pelo cliente, o handshake TLS está oficialmente concluído com segurança.
- **Dados de aplicação (Pacotes subsequentes):** Com o canal TLS completamente estabelecido, os dados de nível de aplicação HTTP passam a fluir encapsulados e blindados pela criptografia simétrica (HTTPS).

C. Comparação HTTP × HTTPS

D. Discussão Técnica

- **Por que o conteúdo HTTP é visível?** O protocolo HTTP padrão opera inteiramente na camada de aplicação sem nenhuma camada de segurança subjacente. Como não possui criptografia, todos os dados trafegam pela rede em plain text (ASCII puro). Qualquer interceptador no caminho consegue ler integralmente o corpo das requisições, respostas, cabeçalhos e dados sensíveis.
- **Por que o conteúdo HTTPS não é visível?** O HTTPS introduz uma camada intermediária de segurança (o protocolo TLS) entre o transporte (TCP) e a aplicação (HTTP). Após o estabelecimento da conexão, os dados são cifrados por

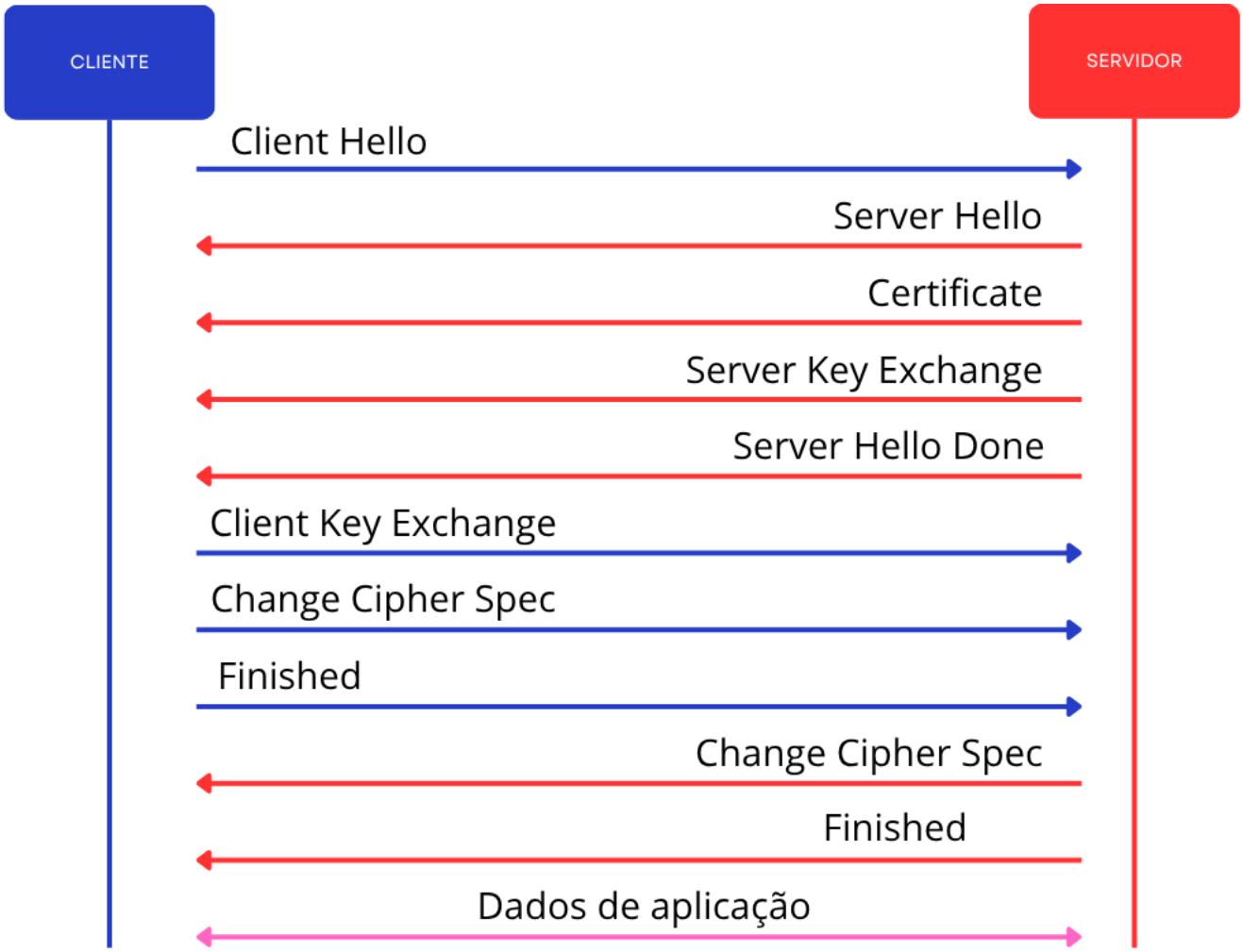


Figura 6. Diagrama de Sequência do Handshake TLS

```
TLSv1.2      268 Client Hello (SNI=example.com)
TCP           74 443 → 49186 [ACK] Seq=1 Ack=195 Win=131072 Len=0
TLSv1.2     4154 Server Hello, Certificate
TLSv1.2      492 Certificate Status, Server Key Exchange, Server Hello Done
TCP           74 49186 → 443 [ACK] Seq=195 Ack=4499 Win=65280 Len=0
TLSv1.2      167 Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
TLSv1.2      332 New Session Ticket, Change Cipher Spec, Encrypted Handshake Message
```

Figura 7. Destaque Mensagens do Handshakes TLS

algoritmos de criptografia simétrica com chaves exclusivas geradas para aquela sessão. Isso garante a confidencialidade, tornando o conteúdo completamente ilegível para qualquer agente externo à comunicação.

- **Quais informações permanecem expostas mesmo com TLS?** Durante o estágio de Handshake TLS v1.2, certas informações precisam ser trocadas em texto aberto antes que o canal seguro seja estabelecido. Permanecem expostos na rede: os números aleatórios de entropia (nonces)(Client/Server Random), os algoritmos de criptografia suportados e escolhidos (Cipher Suites), o nome do domínio de destino (através da extensão SNI - Server Name Indication), as chaves públicas para troca de segredos e o certificado digital do servidor.

Tabela I
TABELA COMPARATIVA: HTTP VS HTTPS

Aspecto	HTTP	HTTPS
Criptografia	Não possui. Os dados trafegam em plain text.	Utiliza TLS/SSL para criptografar todo o canal de comunicação.
Integridade	Não garante. Vulnerável a modificações de dados em trânsito (Tampering).	Garante que os dados não foram alterados usando códigos de autenticação (MAC/HMAC).
Autenticação	Não possui. Não há garantia de que o servidor é quem diz ser.	Autentica a identidade do servidor (e opcionalmente do cliente) por meio de Certificados Digitais.
Confidencialidade	Não possui. Qualquer nó intermediário na rede pode interceptar e ler o tráfego.	Alta. Os dados tornam-se ilegíveis para interceptadores, protegendo informações sensíveis.

PARTE III – CERTIFICADOS DIGITAIS E INFRAESTRUTURA DE CHAVES PÚBLICAS

Nesta parte, foram investigados os certificados digitais de três serviços HTTPS distintos, utilizando o comando OpenSSL para inspeção direta:

```
openssl s_client -connect SITE:443 -servername SITE < /dev/null
    | openssl x509 -noout -text
```

O parâmetro `-servername` foi utilizado para garantir o correto funcionamento do SNI (Server Name Indication), necessário quando múltiplos domínios compartilham o mesmo endereço IP.

Atividade 3.1 – Inspeção de Certificados

Os três serviços selecionados foram **google.com**, **nubank.com.br** e **gov.br**, escolhidos por representarem contextos distintos: uma big tech internacional, uma instituição financeira brasileira e um serviço governamental federal. A Tabela II resume os principais campos extraídos de cada certificado.

Tabela II
COMPARAÇÃO DOS CERTIFICADOS DIGITAIS ANALISADOS

Campo	google.com	nubank.com.br	gov.br
Organização (Subject)	CN=*.google.com	CN=nubank.com.br	O=SERPRO, CN=gov.br
Emissor	Google Trust Services, CN=WR2	Amazon, CN=Amazon RSA 2048 M04	GlobalSign, CN=GlobalSign RSA OV SSL CA 2018
Emissão	22/06/2026	04/07/2026	02/07/2026
Expiração	14/09/2026	17/01/2027	17/01/2027
Algoritmo	ECDSA (chave), RSA-SHA256 (assinatura)	RSA, RSA-SHA256	RSA, RSA-SHA256
Tam. da chave	256 bits (EC, curva P-256)	2048 bits	2048 bits
Validação	DV (Domain Validated)	DV (Domain Validated)	OV (Organization Validated)

Um ponto notável é que o certificado do **gov.br** é do tipo OV (Organization Validated), evidenciado pela presença do campo `O = SERVIÇO FEDERAL DE PROCESSAMENTO DE DADOS (SERPRO)` no Subject — isso indica que a CA verificou a identidade jurídica da organização antes de emitir o certificado. Já os certificados de google.com e nubank.com.br são DV (Domain Validated), nos quais a CA verifica apenas a posse do domínio, sem checar a identidade da organização por trás dele.

Outro ponto de destaque é a validade bem mais curta do certificado do google.com (aproximadamente 3 meses), refletindo uma tendência recente da indústria (impulsionada pelo CA/Browser Forum) de reduzir o tempo de vida dos certificados como forma de diminuir a janela de exposição em caso de comprometimento de chave.

Atividade 3.2 – Construção da Cadeia de Confiança

Para cada certificado, a cadeia completa foi obtida através do comando:

`openssl s_client -connect SITE:443 -servername SITE`

analisando a seção `Certificate chain` da saída, que lista cada elo da cadeia junto de seu emissor.

Cadeia do google.com:

GlobalSign Root CA (self-signed) → GTS Root R1 → Google Trust Services WR2 → *.google.com

Cadeia do nubank.com.br:

Starfield Services Root CA G2 (self-signed) → Amazon Root CA 1 → Amazon RSA 2048 M04 → nubank.com.br

Cadeia do gov.br:

GlobalSign Root CA (self-signed) → GlobalSign Root CA - R3 → GlobalSign RSA OV SSL CA 2018 → gov.br

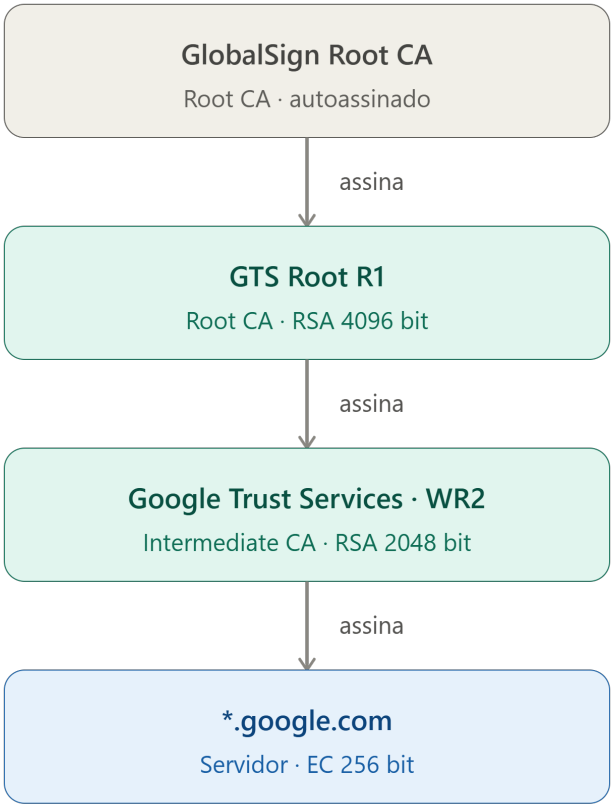


Figura 8. Cadeia de confiança do certificado de google.com

Nota-se, em todos os três casos, o uso da técnica de *cross-signing*: uma Root CA relativamente nova (GTS Root R1, Amazon Root CA 1) é assinada por uma Root CA mais antiga já amplamente distribuída nos trust stores dos sistemas operacionais e navegadores, garantindo compatibilidade retroativa até que a nova raiz seja incorporada de forma independente.

Como ocorre a validação: o navegador valida a cadeia de baixo para cima, verificando se a assinatura de cada certificado corresponde à chave pública do seu emissor, até alcançar uma Root CA que já esteja pré-instalada e marcada como confiável no trust store do sistema operacional ou do próprio navegador.

Como o navegador verifica a autenticidade: além da verificação criptográfica das assinaturas, o navegador confere se o domínio acessado corresponde ao campo `Subject Alternative Name (SAN)` do certificado, se a data atual está dentro do período de validade (`Not Before`/`Not After`), e consulta mecanismos de revogação como OCSP ou CRL para confirmar que o certificado não foi revogado.

O que acontece quando a cadeia é quebrada: se um certificado intermediário estiver ausente, se alguma assinatura não corresponder, ou se a Root CA não estiver presente no trust store, o navegador não consegue reconstruir o caminho de

confiança até uma âncora confiável. Nesse caso, a conexão é considerada não confiável e o navegador exibe um aviso de erro de certificado, bloqueando o acesso por padrão.

Atividade 3.3 – Uso do OpenSSL

Os comandos executados e a metodologia de extração dos dados estão descritos ao longo desta seção. A Figura 9 ilustra a saída obtida para o certificado de google.com.

```
carlos@LAPTOP-8AS58HL2:~$  openssl s_client -connect google.com:443
CONNECTED(00000003)
depth=2 C = US, O = Google Trust Services LLC, CN = GTS Root R1
verify return:1
depth=1 C = US, O = Google Trust Services, CN = WR2
verify return:1
depth=0 CN = *.google.com
verify return:1
---
Certificate chain
 0 s:CN = *.google.com
   i:C = US, O = Google Trust Services, CN = WR2
   a:PKEY: id-ecPublicKey, 256 (bit); sigalg: RSA-SHA256
   v:NotBefore: Jun 22 08:35:23 2026 GMT; NotAfter: Sep 14 08:35:22 2026 GMT
 1 s:C = US, O = Google Trust Services, CN = WR2
   i:C = US, O = Google Trust Services LLC, CN = GTS Root R1
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: Dec 13 09:00:00 2023 GMT; NotAfter: Feb 20 14:00:00 2029 GMT
 2 s:C = US, O = Google Trust Services LLC, CN = GTS Root R1
   i:C = BE, O = GlobalSign nv-sa, OU = Root CA, CN = GlobalSign Root CA
   a:PKEY: rsaEncryption, 4096 (bit); sigalg: RSA-SHA256
   v:NotBefore: Jun 19 00:00:42 2020 GMT; NotAfter: Jan 28 00:00:42 2028 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIIIdjCCB16gAwIBAgIRAK4Gjci98+dXCgxq+znC6cUwDQYJKoZIhvcNAQELBQAw
OzELMAkGA1UEBhMCVVMxHjAcBgNVBAoTFUdvb2dsZSBUcnVzdCBTZXJ2aWNlczEM
MAoGA1UEAxMDV1IyMB4XDTI2MDYyMjA4MzUyM1oXDTI2MDkxNDA4MzUyMlowFzEV
MBMGA1UEAwwMKi5nb29nbGUuY29tMFkwEwYHKoZIzj0CAQYIKoZIzj0DAQcDQgAE
cd/JCJvwVQhwgim0lbAhmIBHt1U8jeUJRYm9JKb86GwYqCml8M+c7OdZAPPyfq3o
e8o1CBpSFuXZANCAhS73AaOCBmIwggZeMA4GA1UdDwEB/wQEAwIHgDATBgNVHSUE
DDAKBggrBgEFBQcDATAMBgNVHRMBAf8EAjAAMB0GA1UdDgQWBBQt4C2kjl2802sf
6IxinN4mLCMH+jAfBgNVHSMEGDAWgBTeGx7teRXUPjckwyG77DQ5bUKyMDBYBggr
BgEFBQcBAQRMMEowIQYIKwYBBQUHMAGGFWh0dHA6Ly9vLnBraS5nb29nL3dyMjAl
BggrBgEFBQcwAoYZaHR0cDovL2kucGtpLmdvb2cvd3IyLmNydDCCBDgGA1UdEQSC
BC8wggQrggwqLmdvb2dsZS5jb22CFiouYXBwZW5naW5lLmdvb2dsZS5jb22CCSou
YmRuLmRldoIVKi5vcmlnaW4tdGVzdC5iZG4uZGV2ghIqLmNsb3VkLmdvb2dsZS5j
b22CGCouY3Jvd2Rzb3VyY2UuZ29vZ2xlLmNvbYIYKi5kYXRhY29tcHV0ZS5nb29n
bGUuY29tggsqLmdvb2dsZS5jYYILKi5nb29nbGUuY2yCDiouZ29vZ2xlLmNvLmlu
gg4qLmdvb2dsZS5jby5qcIIOKi5nb29nbGUuY28udWuCDyouZ29vZ2xlLmNvbS5h
```

Figura 9. Consulta ao certificado de google.com via OpenSSL

PARTE IV – ANÁLISE DE VULNERABILIDADES

Nesta etapa, foi utilizada a ferramenta Nmap para identificar portas abertas e serviços ativos na máquina local, simbolizando um host da rede interna da SecureTech. É importante ressaltar que scans de rede como este só devem ser executados contra hosts sob controle do próprio grupo ou com autorização explícita, dado que sua utilização contra terceiros sem consentimento pode configurar violação legal.

Atividade 4.1 – Descoberta de Serviços

O comando utilizado foi:

```
sudo nmap -sV -sC localhost
```

onde a flag `-sV` realiza a detecção de versão dos serviços, e `-sC` executa os scripts padrão do NSE (Nmap Scripting Engine), que trazem informações complementares sobre cada serviço.

```
carlos@LAPTOP-8AS58HL2: $ sudo nmap -sV -sC localhost
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-08 20:37 -03
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000030s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
80/tcp   open  http    Apache httpd 2.4.58
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: 403 Forbidden
631/tcp  open  ipp     CUPS 2.4
| http-robots.txt: 1 disallowed entry
|_/
|_http-server-header: CUPS/2.4 IPP/2.1
|_http-title: Home - CUPS 2.4.7
3306/tcp open  mysql   MySQL 5.5.5-10.11.13-MariaDB-0ubuntu0.24.04.1
| mysql-info:
|   Protocol: 10
|   Version: 5.5.5-10.11.13-MariaDB-0ubuntu0.24.04.1
|   Thread ID: 32
|   Capabilities flags: 63486
|   Some Capabilities: Speaks41ProtocolOld, Support41Auth, SupportsLoadDataLocal, DontAllowDatabaseTableColumn, SupportsTransactions, ODBCClient, Speaks41Pr
otocolNew, ConnectWithDatabase, InteractiveClient, LongColumnFlag, IgnoreSigpipes, SupportsCompression, FoundRows, IgnoreSpaceBeforeParenthesis, SupportsMul
tipleStatments, SupportsAuthPlugins, SupportsMultipleResults
|   Status: Autocommit
|   Salt: 5S'b<BvOd+HhRC921=~%
|_  Auth Plugin Name: mysql_native_password
Service Info: Host: LAPTOP-8AS58HL2.localdomain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.78 seconds
```

Figura 10. Resultado do scan Nmap na máquina local

Foram identificadas três portas abertas, resumidas na Tabela III.

Tabela III
SERVIÇOS IDENTIFICADOS PELO NMAP

Porta	Serviço	Versão
80	HTTP	Apache http 2.4.58 (Ubuntu)
631	IPP	CUPS 2.4.7
3306	MySQL	MariaDB 10.11.13 (protocolo MySQL 5.5.5)

Na porta 80, foi identificada a aplicação web de teste `sqli-login.php`, uma página de login intencionalmente vulnerável, utilizada como alvo de estudo para vulnerabilidades de SQL Injection.

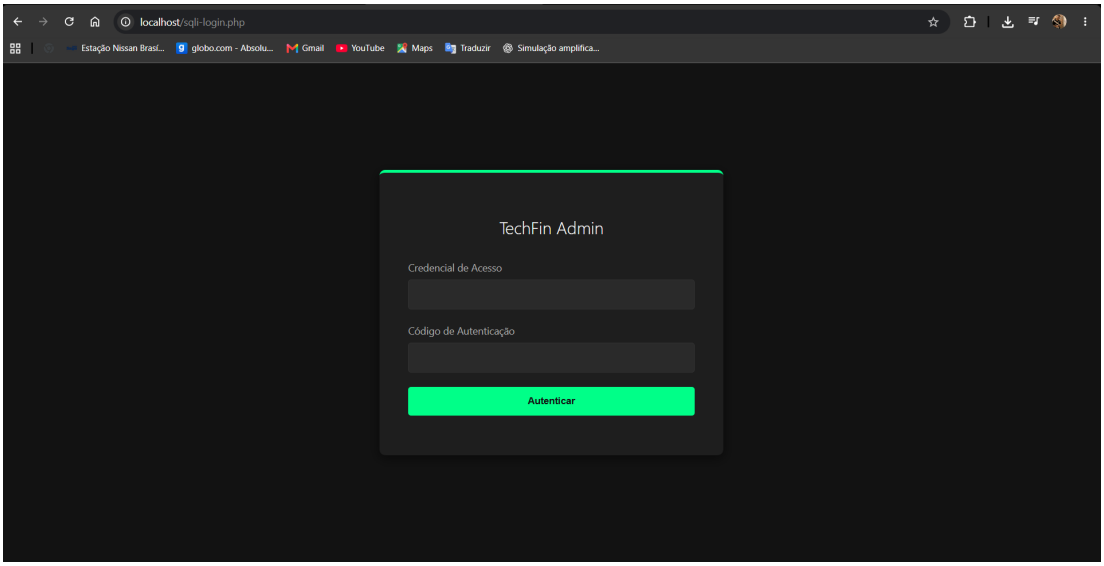


Figura 11. Página de login da aplicação

Atividade 4.2 – Classificação dos Riscos

Para cada serviço identificado, foram analisadas sua função, as possíveis ameaças associadas e o nível de risco correspondente:

- **Porta 80 (Apache/HTTP)**: hospeda a aplicação web da empresa, incluindo o formulário de login. A presença de uma página vulnerável a SQL Injection representa risco crítico, pois pode permitir bypass de autenticação e acesso não autorizado ao banco de dados subjacente. Além disso, a ausência de HTTPS expõe credenciais e dados trafegados em texto claro.
- **Porta 631 (CUPS/IPP)**: serviço de impressão que expõe uma interface administrativa web. Historicamente, o CUPS já apresentou vulnerabilidades críticas de execução remota de código. Sua exposição desnecessária amplia a superfície de ataque sem agregar valor de negócio à aplicação principal.
- **Porta 3306 (MySQL/MariaDB)**: banco de dados que armazena os dados da aplicação. O próprio Nmap conseguiu extrair informações sensíveis do serviço (versão exata, salt de autenticação, plugins suportados) apenas por estar acessível na rede. Bancos de dados nunca deveriam estar diretamente expostos, devendo ser acessíveis apenas pela aplicação, via rede interna ou localhost.

Atividade 4.3 – Relatório de Vulnerabilidades

Tabela IV
RELATÓRIO DE VULNERABILIDADES IDENTIFICADAS

Serviço	Porta	Risco	Mitigação
Apache HTTP (app web com SQLi)	80	Alto	Sanitização de entradas, uso de prepared statements, WAF, migração para HTTPS
CUPS (IPP)	631	Médio	Desabilitar o serviço se não utilizado; caso necessário, restringir acesso apenas à rede local e manter atualizado
MySQL/MariaDB	3306	Alto	Restringir bind apenas a localhost/rede interna, autenticação forte, firewall bloqueando acesso externo à porta

PARTE V – PROJETO E IMPLEMENTAÇÃO DE FIREWALL

Atividade 5.1 – Definição da Política de Segurança

A política de segurança foi definida utilizando o princípio do menor privilégio, que consiste em garantir ao usuário acesso apenas ao que é absolutamente necessário para desempenhar suas tarefas. Dessa forma, a política permite apenas os serviços

essenciais para o funcionamento da empresa SecureTech, bloqueando todo o restante. Os serviços permitidos incluem HTTPS, DNS e SSH (apenas a administradores), enquanto os restritos são Telnet, FTP e os demais.

Tabela V
SERVIÇOS PERMITIDOS

Serviço	Porta	Protocolo	Justificativa
HTTPS	443	TCP	Comunicação segura com o Web Server da empresa
DNS	53	UDP	Resolução de nomes da rede
SSH (Administradores)	22	TCP	Administração remota segura

Tabela VI
SERVIÇOS RESTRITOS

Serviço	Porta	Protocolo
Telnet	23	Transmite senhas em plaintext
FTP	21	Não utiliza criptografia
Demais	Qualquer	Redução da superfície de ataque

Atividade 5.2 – Construção da Matriz de Regras

Tabela VII
MATRIZ DE REGRAS

Origem	Destino	Serviço	Porta	Ação
Internet	Web Server	HTTPS	443	Permitir
Internet	DNS Server	DNS	53	Permitir
ADMS	Servidor SSH (roteador)	SSH	22	Permitir
Internet	Rede interna	Telnet	23	Rejeitar
Internet	Rede interna	FTP	21	Rejeitar
Internet	Rede interna	Qualquer outro	Todas	Rejeitar

Atividade 5.3 – Implementação

Para modelagem da rede, foi utilizada a ferramenta Cisco Packet Tracer 9.0.0. A arquitetura da rede é formada por um Internet-PC, que representa a Internet, um roteador Router0, um switch Switch0, dois servidores, Web Server e DNS Server, bem como dois computadores, ADM-PC e USER-PC, como mostra a figura 12. No roteador, foi implementado a lógica do SSH, ou seja, apenas o ADM-PC consegue acessar remotamente o terminal do roteador. Além disso, para representar a matriz de regras, utilizou-se access lists, representadas na figura 13.

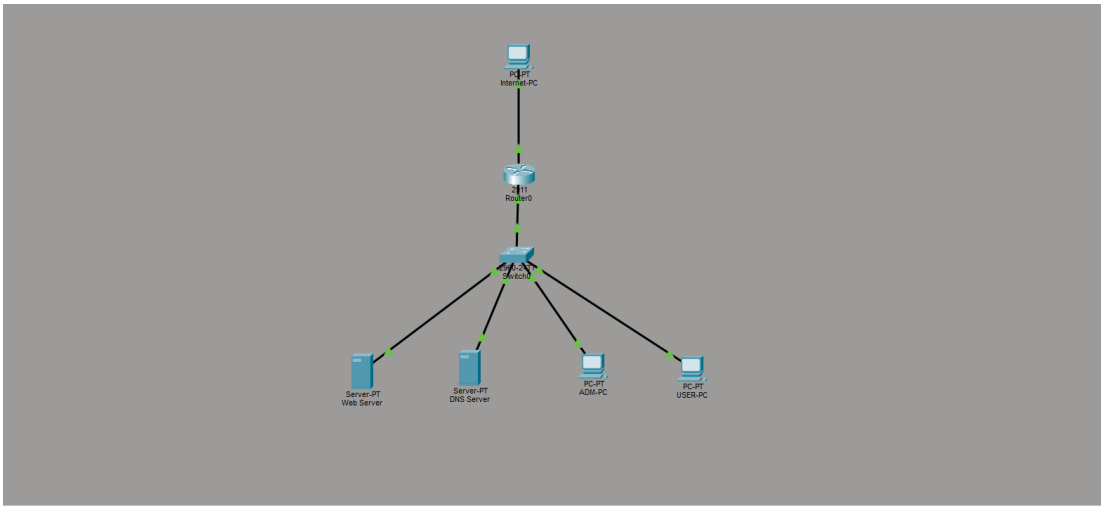


Figura 12. Topologia da rede

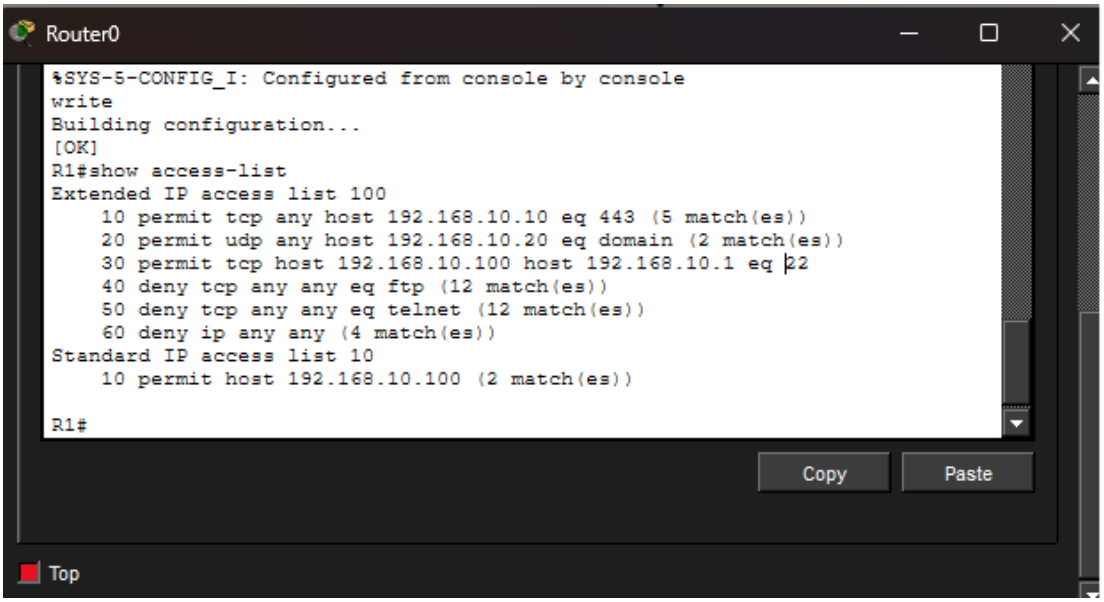


Figura 13. ACLs no Packet Tracer

Atividade 5.4 – Testes de Validação

A partir dos testes realizados, constatou-se que a rede atende aos requisitos propostos. A partir do computador Internet-PC, uma página https foi requisitada "https://intranet.securetech.local"e obteve-se resposta do Web Server, evidenciando que os serviços HTTPS e DNS (na resolução de nomes) são permitidos (figura 14). Também foi realizado requisição Telnet e FTP, mas ocorreu timeout em ambas (figura 15). Na figura 17, percebe-se que foi possível acessar remotamente o terminal do roteador Router0 por um computador da administração (SSH), mas quando a tentativa era em outro PC, USER-PC, a conexão era recusada (figura 16). Por sim, na figura 18, observa-se que a partir de Internet-PC, ocorreu a resolução de nomes DNS, mas, visto que ip usa ICMP, o roteador bloqueia o ping.

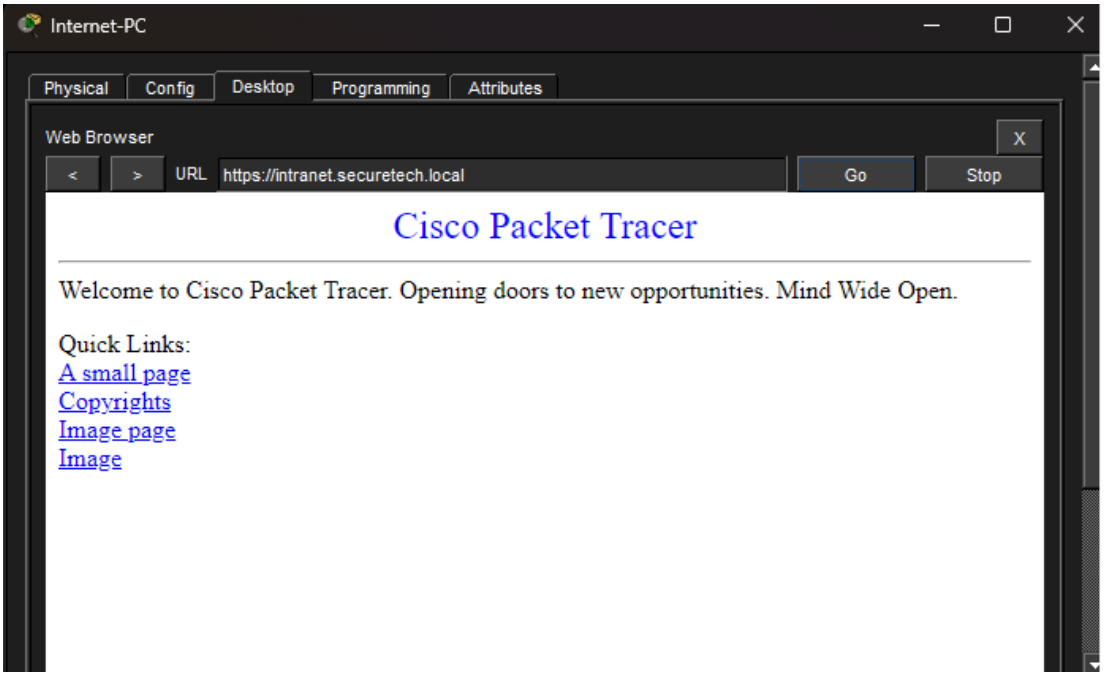


Figura 14. Teste permitido - HTTPS

Atividade 5.5 – Avaliação dos Resultados

O firewall protege contra invasões? Em partes, porque apesar de o firewall conseguir controlar o tráfego entre redes e impedir conexões não autorizadas, reduzindo a superfície de ataque, ele não elimina vulnerabilidades que podem estar presentes em serviços autorizados. Por exemplo, se um servidor HTTPS possuir uma falha de software, um invasor poderá explorá-la através da porta permitida.

O firewall protege contra malware interno? Não necessariamente, visto que caso um computador interno esteja infectado, o malware poderá também utilizar conexões permitidas (como HTTPS) para se comunicar com servidores externos. Além disso, o firewall implementado não detecta códigos maliciosos nem analisa o comportamento das aplicações.

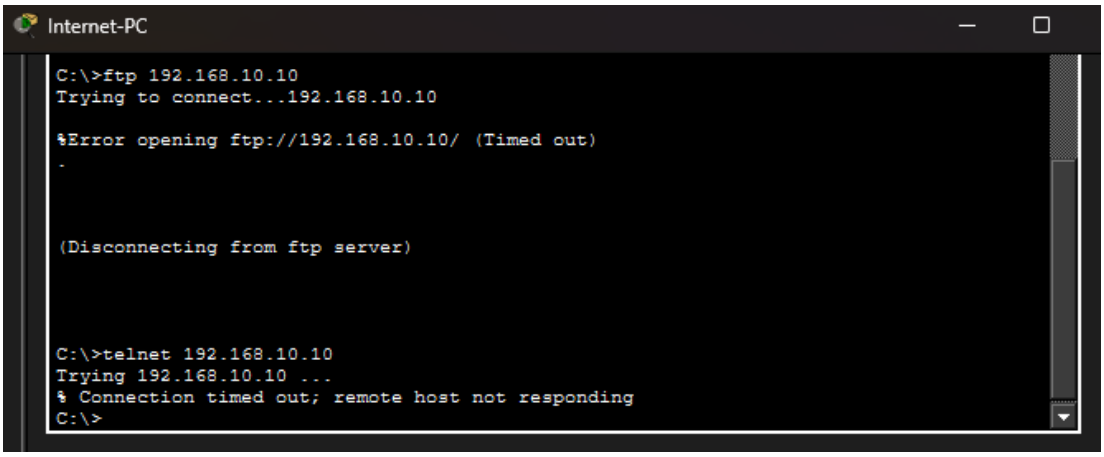


Figura 15. Testes bloqueados - Telnet e FTP

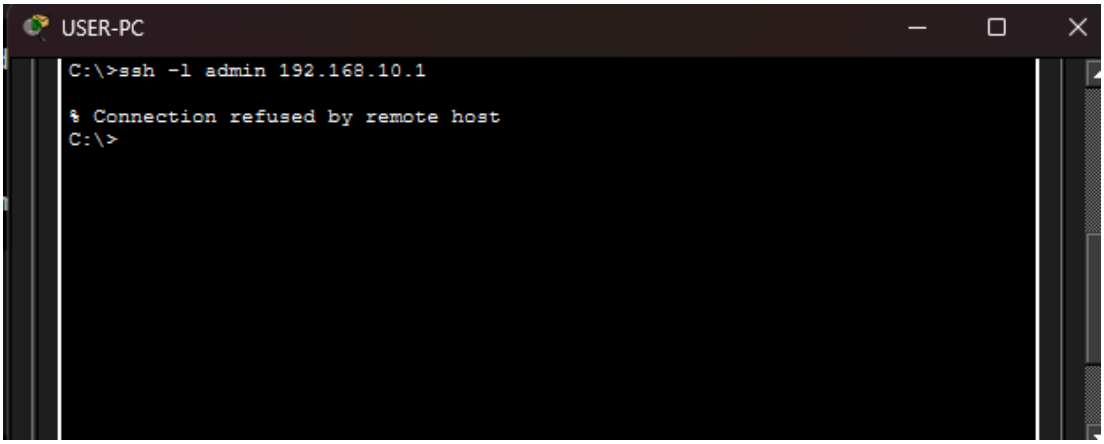


Figura 16. Teste bloqueado - SSH não autorizado

O firewall protege contra phishing? Não, porque ataques de phishing exploram a engenharia social, induzindo o usuário a fornecer informações confidenciais. Como esses acessos muitas vezes utilizam HTTPS, o firewall não consegue distinguir um site legítimo de um site fraudulento apenas com base nas portas ou protocolos utilizados.

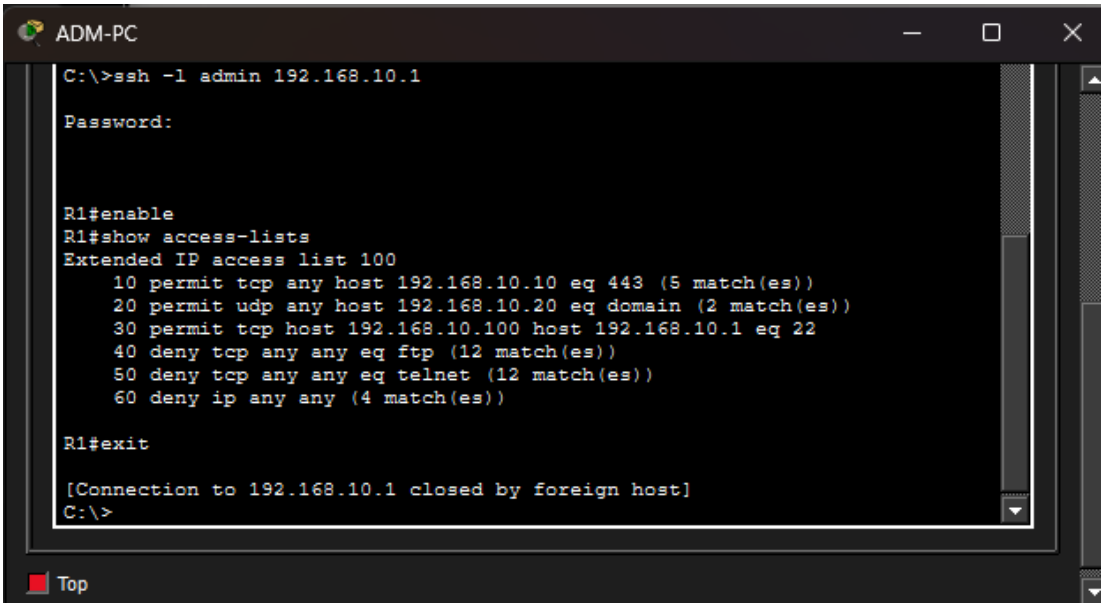


Figura 17. Teste permitido - SSH autorizado

PARTE VI – Estudo de um Ataque Real: DDoS (Distributed Denial of Service)

Atividade 6.1 – Descrição do ataque

O Distributed Denial of Service (DDoS) é um ataque cujo objetivo é tornar um serviço ou até a própria rede indisponível para seus usuários, ou seja, um ataque de negação de serviço distribuído. Sua diferença para um simples ataque DoS (Denial of Service) é que esta consiste em apenas uma máquina tentando comprometer a rede, enquanto o primeiro apresenta centenas ou milhares de dispositivos comprometidos, formando uma botnet, que envia um grande volume de requisições simultaneamente ao alvo. Dessa forma, os recursos do servidor (CPU, memória, largura de banda ou número de conexões) são esgotados, impedindo o estabelecimento de novas solicitações. Esse tipo de ataque compromete principalmente o princípio da disponibilidade, um dos pilares de segurança computacional (Confidencialidade, Integridade e Disponibilidade).

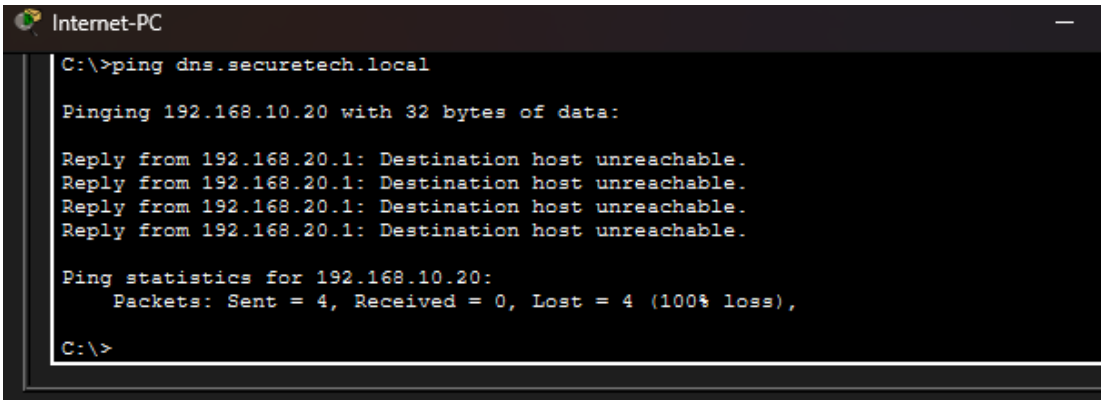


Figura 18. Teste permitido - DNS

Atividade 6.2 – Funcionamento do ataque

O funcionamento do ataque DDoS pode ser dividido nas seguintes etapas: Primeiro, o atacante utiliza um malware para infectar diversos computadores ou dispositivos IoT, formando uma botnet que fica sob o controle do mesmo. Em seguida, ele envia um comando para que todos os dispositivos iniciem o ataque simultaneamente, gerando inúmeras requisições ao servidor da vitma. Dessa forma, o servidor dela é inundada de tal forma que sobrecarrega todos os seus recursos, impedindo que outros usuários legítimos possam estabelecer novas conexões. Esse modelo de ataque pode ser volumétrico, em que a largura de banda da vítima é saturada com grandes quantidades de tráfego, de protocolo, que explora vulnerabilidades dos protocolos de comunicação (SYN Flood, que explora falha no three-way handshake do TCP) e também pode ser direcionado à camada de aplicação, onde serviços específicos são atacados a partir de requisições aparentemente legítimas.

Atividade 6.3 – Protocolos envolvidos

Alguns protocolos que podem ser utilizados dependendo do tipo de ataque DDoS são apresentados na Tabela.

Tabela VIII
PROTOCOLOS ENVOLVIDOS

Serviço	**Porta**
IP	Endereçamento e roteamento dos pacotes.
TCP	Utilizado em ataques como SYN Flood, explorando o processo de estabelecimento de conexões, three-way handshake.
UDP	Envio de grandes volumes de pacotes sem necessidade de conexão prévia.
DNS	Utilizado em ataques de amplificação, nos quais servidores DNS respondem com mensagens muito maiores do que as requisições recebidas.

Atividade 6.4 – Vulnerabilidades exploradas

Os ataques DDoS exploram principalmente limitações de capacidade dos sistemas e algumas características dos protocolos de rede. Entre elas estão a ausência de mecanismos de limitação de tráfego (Rate Limiting); servidores com pouca capacidade de processamento e/ou largura de banda; protocolos suscetíveis à amplificação, como o DNS; vulnerabilidades no estabelecimento de conexões TCP (SYN Flood); dispositivos IoT mal configurados ou com senhas fracas, frequentemente utilizados para formar botnets; falta de sistemas de detecção e mitigação de ataques.

Atividade 6.5 – Mecanismos de mitigação

Algumas técnicas que podem ser empregadas para reduzir os impactos desse ataque são:

Implementação de firewalls e listas de controle de acesso (ACLs) para bloquear tráfego indesejado, como o que foi implementando na Parte V; Configuração de Rate Limiting, limitando a quantidade de conexões por endereço IP; Utilização de sistemas IDS/IPS para detectar padrões de ataque; Balanceamento de carga (Load Balancing) e distribuição dos serviços entre múltiplos servidores para que nenhum servidor seja sobrecarregado, bem como uso de CDNs para distribuir as requisições; Monitoramento contínuo da infraestrutura para identificar comportamentos anormais rapidamente.

I. CONCLUSÕES

Ao longo deste projeto, foi possível analisar de forma prática diversos mecanismos relacionados à segurança em redes corporativas, desde a captura de tráfego não criptografado até a implementação de políticas de firewall e o estudo de ataques reais. As atividades evidenciaram a importância da utilização de protocolos seguros, como o HTTPS aliado ao TLS, e do uso de certificados digitais para garantir a confidencialidade, integridade e autenticidade das comunicações. Além disso, a análise de vulnerabilidades e a implementação de ACLs demonstraram como políticas de controle de acesso reduzem a superfície de ataque, embora não sejam suficientes para eliminar todas as ameaças. Por fim, o estudo do ataque DDoS reforçou que a proteção de uma infraestrutura depende da adoção de múltiplas camadas de segurança, combinando mecanismos preventivos, monitoramento contínuo e boas práticas de administração de redes.

REFERÊNCIAS

[1] KUROSE, J. F.; ROSS, K. W. *Redes de Computadores e a Internet: Uma Abordagem Top-Down*. 6. ed. São Paulo: Pearson, 2013.

[2] TANENBAUM, A. S.; WETHERALL, D. *Redes de Computadores*. 5. ed. São Paulo: Pearson, 2011.